

AuthFilter.java

```
package com.harisudhan.harisudhanmart.filter;

import java.io.IOException;
import javax.servlet.Filter;
import javax.servlet.FilterChain;
import javax.servlet.FilterConfig;
import javax.servlet.ServletException;
import javax.servlet.ServletRequest;
import javax.servlet.ServletResponse;
import javax.servlet.annotation.WebFilter;
import javax.servlet.http.HttpServletRequest;
import javax.servlet.http.HttpServletResponse;
import javax.servlet.http.HttpSession;

/**
 * Session check for protected routes. Applied to /api/v1/* except the public auth and health
 * endpoints, and to /cart, /orders, /admin JSP-backed routes.
 */
@WebFilter(urlPatterns = {
    "/api/v1/cart/*", "/api/v1/orders/*", "/api/v1/admin/*",
    "/api/v1/products/create", "/api/v1/products/update", "/api/v1/products/delete",
    "/api/v1/reviews/*", "/api/v1/chat/*"
})
public class AuthFilter implements Filter {

    @Override
    public void init(FilterConfig filterConfig) { }

    @Override
    public void doFilter(ServletRequest req, ServletResponse res, FilterChain chain)
        throws IOException, ServletException {
        HttpServletRequest request = (HttpServletRequest) req;
        HttpServletResponse response = (HttpServletResponse) res;

        HttpSession session = request.getSession(false);
        if (session == null || session.getAttribute("userId") == null) {
            response.setStatus(HttpServletResponse.SC_UNAUTHORIZED);
            response.setContentType("application/json");
            response.getWriter().write(
                "{\"success\":false,\"data\":null,\"error\":{\"code\":\"UNAUTHENTICATED\",\"message\":\"Login required\"}}");
            return;
        }

        // Admin-only sub-tree
        if (request.getRequestURI().contains("/api/v1/admin/")
            && !"ADMIN".equals(session.getAttribute("role"))) {
            response.setStatus(HttpServletResponse.SC_FORBIDDEN);
            response.setContentType("application/json");
            response.getWriter().write(
                "{\"success\":false,\"data\":null,\"error\":{\"code\":\"FORBIDDEN\",\"message\":\"Admin role required\"}}");
            return;
        }

        chain.doFilter(request, response);
    }

    @Override
    public void destroy() { }
}
```